CSA6303 – THREAT INTELLIGENCE AND NETWORK SECURITY

AT1: APPLICATION-BASED QUESTIONS

Topics: Network Security Fundamentals | Security Goals (CIA Triad) | Types of Network Threats |Introduction to Threat Intelligence Types of Threat Intelligence (Strategic, Tactical, perational) — Threat Intelligence Lifecycle — Applications in IT Industry

CO1: Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.

Dr.V.Parthipan **Total: 50**

Student Name : B.Venkateswarlu

Register number:192465033

Code of Conduct:

I **B.Venkateswarlu (192465033)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **B.Venkateswarlu**

Q1. CIA Triad — Scenario Identification

The primary CIA Triad principle violated in this scenario is Integrity.

Integrity means maintaining the accuracy, completeness, and trustworthiness of information and preventing unauthorized changes. In the given situation, an attacker gains write access to the e-commerce database and silently changes product prices. The prices are no longer reliable because the changes were made without authorization.

Confidentiality is not necessarily violated because the scenario does not state that the attacker viewed or disclosed private customer information. Availability is not violated because the website remains online and customers can continue using it. However, if the attacker had also accessed or disclosed confidential information, Confidentiality could be affected as well.

Conclusion: Integrity is violated because database information has been modified without authorization. There is no evidence in the scenario that Confidentiality or Availability has been directly violated.

Q2. Risk Quantification — Annualized Loss Expectancy

Given data:

- Asset Value (AV) = $50,000
- Exposure Factor (EF) = 40% = 0.40
- Annualized Rate of Occurrence (ARO) = 2 incidents per year

Step 1: Calculate Single Loss Expectancy (SLE). SLE is the estimated monetary loss caused by one occurrence of a threat.

Formula: SLE = Asset Value × Exposure Factor

Calculation: SLE = $50,000 × 0.40 = $20,000

Therefore, Single Loss Expectancy (SLE) = $20,000.

Step 2: Calculate Annualized Loss Expectancy (ALE). ALE estimates the expected loss from this threat over a period of one year.

Formula: ALE = SLE × Annualized Rate of Occurrence (ARO)

Calculation: ALE = $20,000 × 2 = $40,000 per year

Therefore, Annualized Loss Expectancy (ALE) = $40,000 per year.

Interpretation: If the threat occurs about twice per year and each incident causes a loss equal to 40% of the database value, the expected annual loss is $40,000. This is an estimate based on the supplied figures; actual losses may vary depending on recovery costs, business interruption, and other consequences.

Q3. Brute-Force Attack Time Estimation

Given data:

- Password length (L) = 8 characters
- Character set size (C) = 62: 26 lowercase letters + 26 uppercase letters + 10 digits
- Cracking speed (R) = 1,000,000,000 passwords per second = 10^9 attempts/second

Step 1: Calculate the keyspace. The keyspace is the total number of possible password combinations when each position can contain any of the 62 characters.

Formula: Keyspace (K) = C^L

Calculation: K = 62^8 = 218,340,105,584,896 possible passwords

Step 2: Calculate the worst-case time in seconds. Worst-case time assumes the correct password is the last combination tested, so the attacker must try the entire keyspace.

Formula: Time (seconds) = Keyspace ÷ Attempts per second

Calculation: T = 218,340,105,584,896 ÷ 1,000,000,000 = 218,340.1056 seconds

Step 3: Convert seconds to hours. Since one hour contains 3,600 seconds:

Time (hours) = 218,340.1056 ÷ 3,600 ≈ 60.65 hours

Final answer: The keyspace is 218,340,105,584,896 combinations, and the worst-case exhaustive search time is approximately 60.65 hours (about 2.53 days).

Note: This estimate assumes a constant rate of one billion attempts per second and does not account for delays, password-hashing defenses, account lockouts, or other real-world limitations. Actual cracking time depends heavily on how passwords are stored and protected.

Q4. Risk Prioritization Matrix

Risk scores are calculated by multiplying the likelihood rating by the impact rating. Both ratings range from 1 to 5. A higher score indicates that the threat should generally receive greater attention.

Formula: Risk Score = Likelihood × Impact

Threat	Likelihood	Impact	Risk Score
(a) Ransomware	4	5	4 × 5 = 20
(b) Phishing	5	3	5 × 3 = 15
(c) Insider data theft	2	5	2 × 5 = 10
(d) DDoS	3	3	3 × 3 = 9
(e) Unpatched server exploit	4	4	4 × 4 = 16

Ranked order of patching and budget priority:

Rank	Threat	Risk Score / Priority
1	Ransomware	20 — Very High
2	Unpatched server exploit	16 — High
3	Phishing	15 — High
4	Insider data theft	10 — Moderate
5	DDoS	9 — Moderate

Explanation: Ransomware receives the highest priority because it combines a high likelihood with very high impact and can encrypt data, interrupt business operations, and cause recovery costs. The unpatched server exploit ranks second because an exposed vulnerability may provide unauthorized access and should be patched promptly. Phishing ranks third due to its very high likelihood and potential to steal credentials or deliver malware. Insider data theft has a lower likelihood rating but a high impact, so access controls and monitoring remain important. DDoS ranks fifth based on the supplied scores because it has a lower combined rating than the other threats.

Conclusion: Based strictly on the risk scores, the recommended order is ransomware, unpatched server exploit, phishing, insider data theft, and DDoS. In practice, the organization should also consider whether a vulnerability is actively exploited, whether critical services are exposed, and the possible business impact before making final decisions.

Q5. Passive vs. Active Threat Classification

Scenario	Classification	Primary CIA Principle	Reason
(a) Silently sniffing unencrypted traffic on public Wi-Fi	Passive threat	Confidentiality	The attacker observes communications without changing the transmitted data. Sensitive information may be exposed.
(b) ARP spoofing to redirect traffic	Active threat	Integrity	The attacker manipulates ARP mappings and redirects network traffic. This changes normal network communication and may also expose confidential data.
(c) Long-term network reconnaissance without altering anything	Passive threat	Confidentiality	The attacker gathers information about hosts, services, or network structure without modifying systems or data.

Passive threats mainly involve listening, observing, or collecting information without directly changing system resources. They primarily threaten Confidentiality. Active threats involve modifying data, injecting traffic, impersonating devices, or disrupting normal operations. They may threaten Integrity and Availability, and can also affect Confidentiality.

Conclusion: (a) is passive and primarily threatens Confidentiality; (b) is active and primarily threatens Integrity; and (c) is passive and primarily threatens Confidentiality. ARP spoofing may also compromise Confidentiality if the attacker intercepts sensitive traffic.

Q6. Threat Intelligence Lifecycle Sequencing

The Threat Intelligence Lifecycle is a continuous process that turns a security question into useful information for decision-making. The correct sequence for the given scenario is:

(iii) → (iv) → (i) → (ii) → (v)

1. Planning and Direction — (iii): The executive request is recorded as an intelligence requirement. The SOC clarifies what the CISO needs to know, which ransomware group or industry is involved, and what decision the intelligence should support.

2. Collection — (iv): Analysts collect information from Open-Source Intelligence (OSINT), threat-intelligence feeds, and reports about the group's known indicators of compromise (IOCs) and tactics, techniques, and procedures (TTPs).

3. Processing and Analysis — (i): Analysts organize and evaluate the collected information, then correlate relevant IOCs with internal security logs. They look for evidence of suspicious activity and assess whether the organization may be exposed or affected.

4. Dissemination — (ii): The SOC prepares a clear report and sends it to the Chief Information Security Officer (CISO). The report should summarize findings, explain the level of risk, and recommend practical actions such as blocking indicators, checking vulnerable systems, or improving monitoring.

5. Feedback — (v): The CISO's follow-up questions help identify information gaps and refine the next intelligence requirement. This feedback starts another cycle of planning, collection, analysis, and reporting.

Conclusion: The correct order is Planning and Direction → Collection → Processing and Analysis → Dissemination → Feedback. The lifecycle is continuous because new questions and new threat information may require additional investigation.